

BASIC SECURITY AWARENESS ASSESSMENT

Invexom Cybersecurity Internship | Fictional Organization: NovaBridge Solutions

Organization profile	Small professional-services company with approximately 25 employees using email, cloud storage, laptops, mobile devices, and SaaS applications.
Assessment focus	Employee-facing cybersecurity risks and practical prevention controls.
Deliverable scope	12 common security risks + impact analysis + realistic scenarios + recommended prevention + employee checklist.

1. Executive Summary

This basic security awareness assessment identifies common risks that employees at a small organization may encounter during normal work. The focus is on human-centered attack paths and practical defensive behaviors rather than technical penetration testing. The assessment documents twelve risks and closes with a concise daily employee checklist.

2. Risk Assessment

1. Weak or reused passwords

Risk description	Short, predictable, or reused passwords can be guessed or exposed through credential reuse.
Potential impact	Account takeover, unauthorized access to email and business systems, and possible exposure of customer or internal data.
Example scenario	An employee reuses an old personal password for the company portal. A third-party breach exposes it, and an attacker tries the same password against the work account.
Recommended prevention	Use unique long passwords or passphrases, store them in an approved password manager, and never reuse company passwords on personal sites.

2. Phishing and credential theft

Risk description	Fraudulent emails, messages, or login pages attempt to trick employees into revealing credentials or opening malicious content.
Potential impact	Credential compromise, malware infection, fraud, and unauthorized access to company services.
Example scenario	An employee receives an email that appears to be from Microsoft 365 asking them to verify their account. The link opens a fake login page.
Recommended prevention	Verify unexpected requests, inspect the sender and destination, avoid entering credentials after following suspicious links, and report suspected phishing immediately.

3. Unsafe downloads and malicious attachments

Risk description	Unverified applications, cracked software, or suspicious email attachments can introduce malware.
Potential impact	Malware infection, data loss, ransomware, credential theft, and disruption of business operations.
Example scenario	An employee downloads a free utility from an unknown website. The installer also deploys a remote-access trojan.
Recommended prevention	Install software only from approved sources, avoid pirated software, scan unexpected files, and ask IT/security staff when a download is uncertain.

4. Unsecured devices

Risk description	Unlocked or poorly protected laptops and phones can expose company information when lost, stolen, or temporarily unattended.
Potential impact	Data exposure, unauthorized account use, and compromise of saved credentials or sessions.
Example scenario	A laptop containing active company sessions is left unattended in a public place and is taken.
Recommended prevention	Enable automatic screen locking, use device encryption and strong authentication, keep operating systems updated, and report lost devices immediately.

5. Social engineering

Risk description	Attackers manipulate employees through urgency, authority, trust, or fear to bypass normal security procedures.
Potential impact	Fraudulent payments, disclosure of confidential information, unauthorized access, and process bypass.
Example scenario	Someone calls pretending to be a senior manager and urgently asks an employee to share an OTP or change a bank beneficiary.
Recommended prevention	Follow verification procedures, challenge unusual requests, use independent contact methods, and never disclose passwords or one-time codes.

6. Improper data sharing

Risk description	Confidential files may be shared with the wrong person, personal account, public link, or unauthorized application.
Potential impact	Privacy incidents, intellectual-property loss, contractual issues, and reputational damage.
Example scenario	An employee creates a public cloud-sharing link for a spreadsheet containing customer contact details and posts the link in a public chat.
Recommended prevention	Classify sensitive data, share only with authorized recipients, use restricted links with expiry where available, and avoid personal storage accounts for company data.

7. Outdated software and operating systems

Risk description	Missing security updates can leave known vulnerabilities unpatched.
Potential impact	Remote exploitation, malware infections, service disruption, and data compromise.
Example scenario	A browser or operating system has a known security vulnerability, but an employee repeatedly postpones updates for several weeks.
Recommended prevention	Enable automatic updates, restart when required, use supported software versions, and report update failures instead of bypassing them.

8. Untrusted links and websites

Risk description	Malicious or deceptive links can lead to phishing pages, drive-by downloads, or fraudulent websites.
Potential impact	Credential theft, malware installation, financial fraud, or browser/session compromise.
Example scenario	A message contains a shortened URL claiming to show an urgent delivery invoice. The link redirects to a fake payment site.
Recommended prevention	Do not click unexpected links, verify domains before signing in or paying, use bookmarks for important services, and report suspicious URLs.

9. Unsafe public Wi-Fi

Risk description	Open or untrusted networks can increase exposure to interception, rogue access points, and credential theft.
Potential impact	Session hijacking, exposure of traffic, and access to business resources if security controls are weak.
Example scenario	An employee connects to an unknown airport Wi-Fi network and signs in to an internal service.
Recommended prevention	Prefer trusted networks or a company-approved VPN, avoid sensitive transactions on unknown networks, and verify the network name with staff when possible.

10. Unauthorized USB and removable media

Risk description	Unknown USB drives can contain malicious files or be used to copy company information without authorization.
Potential impact	Malware infection, data leakage, and loss of control over sensitive information.
Example scenario	An employee finds a USB drive in the parking area and plugs it into a work laptop to identify the owner.
Recommended prevention	Do not connect unknown devices, use approved removable media only, scan authorized media, and hand found devices to IT/security.

11. Missing multi-factor authentication (MFA)

Risk description	Accounts protected only by passwords have a single primary authentication barrier.
Potential impact	A stolen password may be enough for an attacker to access email, cloud applications, or internal services.
Example scenario	An employee's password is phished and the attacker successfully logs in because MFA is not enabled.
Recommended prevention	Enable MFA on supported accounts, prefer authenticator-app or security-key methods where provided, and report unexpected authentication prompts.

12. Excessive access privileges

Risk description	Users may retain more system or data access than required for their current job responsibilities.
Potential impact	A compromised account can expose or modify a larger amount of company information.
Example scenario	A former project member keeps access to a shared financial folder months after moving to another team.
Recommended prevention	Apply least privilege, review access regularly, remove access promptly when roles change, and use separate admin accounts for administrative tasks.

3. Employee Cybersecurity Checklist

Use this as a daily reminder. Report suspicious activity early rather than trying to investigate it alone.

1	☐ Use a unique, strong password for every company account.
2	☐ Enable MFA wherever it is available.
3	☐ Lock your screen whenever you step away.
4	☐ Treat unexpected email links, attachments, and login requests as suspicious.
5	☐ Verify payment, password-reset, and access-change requests using a trusted channel.
6	☐ Install software and updates only from approved or trusted sources.
7	☐ Never use cracked or pirated software on company devices.
8	☐ Do not plug unknown USB drives or other removable devices into work systems.
9	☐ Share confidential information only with authorized recipients using approved platforms.
10	☐ Avoid sensitive work on untrusted public Wi-Fi; use approved secure access methods.
11	☐ Report lost devices, suspected phishing, malware, or accidental data sharing immediately.
12	☐ Use only the access permissions needed for your role and request removal when no longer required.

4. Basic Response Rule: Stop - Verify - Report

Stop: Do not click, pay, share data, approve access, or disclose credentials when a request looks suspicious.

Verify: Confirm unusual requests using an independent trusted contact method.

Report: Promptly report suspected phishing, malware, lost devices, accidental data sharing, or other security incidents.

5. Scope and Limitations

This is a basic awareness assessment for a fictional organization. It is intended for employee education and does not replace a technical vulnerability assessment, penetration test, formal risk register, incident-response plan, or compliance audit.

6. Conclusion

Security awareness is a shared responsibility. Strong authentication, careful handling of messages and data, secure devices, timely updates, and rapid reporting can reduce the likelihood and impact of common employee-targeted security incidents.